The MESA Framework

A Four-Altitude Diagnostic Model for Institutional AI Governance

Nabeel Khan
iSystematic Inc.
ORCID 0009-0005-5364-914X

Framework Specification, Version 1.1
30 August 2026
doi.org/10.5281/zenodo.22109836
CC BY 4.0

Contents

Abstract **3**

On the name **3**
Change of expansion . . . 4

What MESA is not **4**

Notation **4**

1. Scope and Definitions **4**
1.1 The gap this framework addresses . . . 4
1.2 Definitions . . . 5
1.3 What MESA governs . . . 5
1.4 Explicitly out of scope . . . 6

2. Conceptual Model **6**
2.1 The four altitudes . . . 6
2.2 The canonical diagram . . . 7
2.3 The governance chain . . . 7
2.4 Formal statement . . . 7
2.5 The enforcement constraint . . . 8
2.6 Governance dependency, enforcement dependency and remediation priority . . . 8
2.7 MESA invariants . . . 9

3. Relationship to Existing Frameworks **9**
3.1 Mapping to ISO/IEC 42001:2023 at clause level . . . 9
3.2 Mapping to the NIST AI Risk Management Framework at function and category level . . . 12
3.3 The contribution, stated once . . . 13
3.4 What the reference frameworks provide that MESA does not duplicate . . . 13

4. Structural Properties (Normative) **13**
4.1 Concurrency . . . 13
4.2 Cascade . . . 13
4.3 The enforcement constraint . . . 13
4.4 No fifth layer . . . 14

5. The Four Layers (Normative) **14**

5.1 Layer 1: Regulatory Floor . . . 14
5.2 Layer 2: Strategic Compass . . . 14
5.3 Layer 3: Operational Machinery . . . 15
5.4 Layer 4: Technical Substrate . . . 16

6. Failure Taxonomy (Normative for incident classification) 17

7. Assessment 18
7.1 The maturity scale . . . 18
7.2 The instrument, and this document's dependency on it . . . 18
7.3 Scoring . . . 18
7.4 From profile to remediation sequence . . . 19
7.5 Conformance . . . 19
7.6 Supersession of the Governance Maturity Model . . . 19

8. Limitations, Falsification and Research Agenda 20
8.1 Known limitations . . . 20
8.2 What has not been tested . . . 20
8.3 What would invalidate the framework . . . 21
8.4 Research agenda . . . 21

9. Regulatory Snapshot Discipline (Normative) 22

10. References 22

Appendix A. Representative assessment anchors 24

Appendix B. Sharia-specific implementation profile 25

Appendix C. Illustrative implementation profile 25

Appendix D. Worked example, as a traceability trace 26

Appendix E. Companion specifications 26

Document history 27

About the author 28

Licence 28

How to attribute this work 28

Framework Specification, Version 1.1

Author: Nabeel Khan
ORCID: 0009-0005-5364-914X
Affiliation: iSystematic Inc.
Version: 1.1
Date: 30 August 2026
Licence: Creative Commons Attribution 4.0 International (CC BY 4.0)
DOI (cite this): https://doi.org/10.5281/zenodo.22109836
This version: https://doi.org/10.5281/zenodo.22177681

Cite as: Khan, N. A. (2026). *The MESA Framework: A Four-Altitude Diagnostic Model for Institutional AI Governance. Framework Specification, Version 1.1.* Zenodo. https://doi.org/10.5281/zenodo.22109836

Supplement to: Khan, N. A. (2026). *AI Governance & Compliance Frameworks for the Middle East: The Enterprise Playbook.* iSystematic Inc. ISBN 978-1-0678960-1-0 [22].

Trademark notice. MESA Framework™ is claimed as a trademark of the author and iSystematic Inc. The CC BY 4.0 licence applies to the text of this specification. It grants no rights in the mark. The framework itself may be implemented, taught, assessed against and extended by anyone, with attribution.

Status. This is a specification, not a certification scheme. No conformity assessment body operates against it. Section 7.5 states what a conformance claim means and what it does not.

Abstract

Institutional AI governance is commonly assessed as a single capability and reported as a single grade. That treatment obscures the failure that matters most: an institution can hold current policies, a chartered committee and a complete documentation set while the systems those documents describe cannot produce the evidence the documents claim.

This specification defines the MESA Framework™ (Maturity, Evidence, Substrate, Alignment) around one proposition: **institutional AI governance is an alignment condition across distinct governance altitudes, and governance maturity should therefore be diagnosed as a multidimensional state rather than reported as a single organizational score.** The framework separates governance into four altitudes, each with a definition, its inputs and outputs, a single accountable role, and an evidence requirement an auditor can test: a Regulatory Floor, a Strategic Compass, Operational Machinery and a Technical Substrate.

Five mechanisms operate the architecture: layer separation, cross-layer cascade, an enforcement constraint by which the Technical Substrate bounds the effective state of runtime-dependent controls, mandatory interface couplings between control families, and an evidence-based maturity vector. The framework is calibrated to regulated institutions operating AI systems under more than one binding authority, including institutions for which a Sharia Supervisory Board holds binding approval power; that board sits inside the Regulatory Floor as a binding authority source rather than as an ethical overlay.

MESA does not replace ISO/IEC 42001 or the NIST AI Risk Management Framework. Section 3 maps the four altitudes to those documents at clause and category level and states which implementation decisions each deliberately leaves to the organization and which of those MESA instantiates. What MESA adds is **diagnostic altitude**: a per-layer maturity profile that names which altitude is failing, in place of a single grade that cannot.

Keywords: AI governance; governance altitude; ISO/IEC 42001; NIST AI RMF; model risk management; AI assurance; maturity model; financial services; Islamic finance; Sharia governance; GCC regulation; MESA Framework.

On the name

MESA stands for **Maturity, Evidence, Substrate, Alignment**. The four terms name the properties the framework asserts, and each is drawn from the specification rather than fitted to the letters.

- **Maturity.** The framework reports a per-altitude maturity profile, not a single organizational grade. A single grade is what allows a strong regulatory posture to conceal a substrate that cannot support it.
- **Evidence.** Each altitude carries an evidence requirement an auditor can test. A control that produces no evidence is not a control the institution can defend.
- **Substrate.** The Technical Substrate bounds the effective state of every runtime-dependent control above it. This is the framework's enforcement constraint: a policy at any maturity level operates at the maturity level of the substrate that must enforce it.
- **Alignment.** Institutional AI governance is an alignment condition across distinct governance altitudes. This is the framework's central proposition; the other three are how it is diagnosed, tested and reported.

Read forward, the four terms give the order in which the framework produces its output. Read in reverse, they give the order in which it was derived: Alignment is the proposition, the Substrate bounds it, Evidence tests it, Maturity reports it.

The four terms are not the four altitudes. The altitudes are the Regulatory Floor, the Strategic Compass, Operational Machinery and the Technical Substrate, and they are defined in Section 2. Substrate appears in both lists because the Technical Substrate is both an altitude and the property that makes the enforcement constraint possible; no other correspondence between the two lists is intended.

doi.org/10.5281/zenodo.22109836

Change of expansion

Through version 1.0 and in the Enterprise Playbook [22], MESA was expanded as *Middle East Strategic Alignment*, reflecting the regional context in which the framework was developed and first applied. **That expansion is retired as of version 1.1.**

It is retired because it described the framework's origin rather than its scope, and the two had already diverged. Version 1.0 states that the framework is calibrated to regulated institutions operating AI systems under more than one binding authority source, a condition that is not regional. Institutions in any jurisdiction meet it, including those operating under a financial supervisor and a data protection authority with divergent expectations, those operating across borders, and those for which a Sharia Supervisory Board holds binding approval power.

The framework's name, its four altitudes, its five operating mechanisms and its conformance language are unchanged. **The regional origin is a matter of record and is not disclaimed; it is simply no longer carried in the name.**

A revised expansion invites the charge that it was retrofitted to the letters. The defence is the derivation above rather than a denial: *alignment condition* is the central proposition of version 1.0, *Technical Substrate* is its fourth altitude, *an evidence requirement an auditor can test* is its per-altitude requirement, and the *evidence-based maturity vector* is its fifth mechanism. Nothing was invented to fit a letter.

What MESA is not

Stated at the front so that a reader can establish the boundary before investing in the detail. MESA is not:

- a replacement for ISO/IEC 42001 or the NIST AI Risk Management Framework;
- a regulatory compliance determination, which only a supervisor can make;
- a model development or machine-learning engineering methodology;
- a certification scheme, and no accredited body assesses against it;
- a decision framework for whether a given AI use case should exist at all;
- a technical architecture standard;
- an empirically validated instrument. Section 8 states precisely what has not been tested.

Notation

This specification uses the verbal forms of ISO/IEC Directives Part 2:

- **shall** indicates a requirement. An implementation that does not meet it is not conformant.
- **should** indicates a recommendation. Departure requires a recorded rationale.
- **may** indicates a permission.

Sections 4, 5 and 6 are normative. Sections 1, 2, 3, 7, 8, 9 and the appendices are informative, except where they state a requirement using **shall**.

---

1. Scope and Definitions

1.1 The gap this framework addresses

Two institutions can hold identical documentation and be in entirely different governance conditions. Both have a board-approved AI policy, a chartered committee, a model inventory and a set of validation reports. One can produce, on defined notice, the decision trail behind a named production decision: the input record, the model version, the output, and the explanation that was shown to the affected person at the time. The other cannot. The documentation does not distinguish them.

The distinction is structural. Governance failures are commonly described as policy failures and treated with better policy, which is one reason the treatment so often fails. The more frequent failure is a mismatch between

doi.org/10.5281/zenodo.22109836

altitudes: an obligation recognized at one altitude that no mechanism carries down to the altitude where systems actually run. The institution writes a per-decision explainability requirement into policy. The engineering does not produce the artefact. The validator records the gap. The gap does not close, because the discipline that noticed it is not the capability that closes it.

This premise is stated once, here, and is operationalized rather than restated in the sections that follow.

1.2 Definitions

Governance altitude. The organizational level at which a governance decision, control, or evidence obligation is instantiated. This specification distinguishes four: **regulatory altitude**, where binding obligations are established; **strategic altitude**, where the institution chooses its posture within them; **operational altitude**, where standing institutional machinery converts intent into controls; and **technical altitude**, where controls become properties of running systems.

Altitude mismatch. A condition in which an obligation, decision, control, or enforcement mechanism exists at one governance altitude without an effective interface to the altitude at which its consequence must be realized. Altitude mismatch is the failure class MESA exists to make visible.

Binding authority source. Any party or instrument whose determination is a precondition of the institution's ability to deploy or continue operating an AI system. This includes state regulators and supervisory authorities, contractual commitments carrying regulatory consequence, binding internal authorities, and, where applicable, a Sharia Supervisory Board. The term is deliberately broader than ”regulator”: MESA makes no claim about the legal character of any authority, only about whether its determination binds the institution in fact.

The following four terms are distinguished throughout and shall not be used interchangeably. Their chain is the backbone of the framework.

Requirement. What must be true. A requirement originates at a binding authority source and is recognized at the regulatory altitude.

Control. The institutional process or governance mechanism intended to satisfy a requirement. A control lives at the operational altitude and has a named owner.

Enforcement mechanism. The technical or procedural mechanism that makes a control effective in the running system. An enforcement mechanism lives at the technical altitude.

Evidence. The observable artefact demonstrating that the requirement, control and enforcement mechanism operated as claimed, reproducible rather than reconstructed.

Material change. A change that may alter the applicability, risk classification, control requirements, deployment authority, runtime enforcement capability, or evidence obligations of an AI system. Non-exhaustive examples: entry into a new jurisdiction; a new or amended instrument from a binding authority source; a new model version or a material change to training data; a change of vendor or of a vendor's own subprocessors; a new deployment modality; a new use case for an existing model; a change in risk classification; and a technical architecture change affecting residency, retention, logging or explainability. The cascade requirement in 4.2 is triggered by material change as defined here.

Other terms. ”Institution” means the accountable legal entity or group operating the AI systems in scope. ”AI system” is used in the sense of ISO/IEC 42001:2023 [1]. ”AIMS” means an AI management system in the sense of ISO/IEC 42001:2023. ”MENA” means the Middle East and North Africa.

1.3 What MESA governs

MESA governs the institutional arrangement by which an organization directs, constrains, evidences and corrects its own use of AI systems. In scope:

- **The institution's full AI estate**, including systems built in house, systems embedded in purchased software, and systems reached through third-party services. A system the institution did not knowingly acquire is still in scope once discovered.
- **Regulated institutions operating under more than one binding authority source.** The framework is calibrated to plurality. An institution answering to a single authority can use it, but will find parts of Layer 1 degenerate to a simpler case.

doi.org/10.5281/zenodo.22109836

- **Institutions for which a religious-law authority holds binding approval power**, specifically Islamic financial institutions whose Sharia Supervisory Board can prevent deployment. Section 5.1 places that authority inside the Regulatory Floor.
- **Decisions at institutional altitude**: board risk appetite, committee authority, office structure and staffing, validation policy, deployment gates, incident escalation, vendor concentration, monitoring coverage, evidence retention.

Proposition: MESA is MENA-calibrated, not MENA-exclusive. Layer 1 is jurisdiction-specific and must be reconstructed for each regulatory geography. Layers 2 through 4 are structurally transferable and are written so that another regulated sector or region can populate Layer 1 with its own authority map without altering them. Formally:

> MESA = L1 (jurisdiction-specific) + L2 to L4 (structurally transferable)

The transferability of Layers 2 through 4 is a design claim. Section 8.2 records that it has not been evidenced by a published application outside MENA financial services.

1.4 Explicitly out of scope

Naming these is part of the specification, because a framework used past its boundary produces false assurance.

1. **Whether an AI use case should exist.** MESA operationalizes the governance of a use case that has already cleared the prior question. It records that an institution chose to deploy. It does not assert that the institution should have chosen.
2. **Team-level engineering practice.** Experiment tracking, feature store hygiene, model registry conventions, continuous integration and deployment for models, retraining triggers and sprint decomposition are the subject of a different literature. MESA states what evidence those practices shall produce, not how to run them.
3. **The text of any regulation.** Sections 3 and 10 cite specific instruments as of the date on the title page. Regulatory text is authoritative at the authority, not in this document, and every citation here ages. Section 9 specifies the snapshot discipline that manages this.
4. **Legal, Sharia or investment advice.** This specification is a structural description. An institution applying it should obtain qualified counsel and, where applicable, its own Sharia review.
5. **Certification.** No conformity assessment scheme exists for MESA. An institution assessing itself against ISO/IEC 42001 should use ISO/IEC 42006:2025, which sets requirements for bodies auditing and certifying AI management systems [4].
6. **Motivation.** The framework operationalizes a commitment that already exists. It does not create one.

---

2. Conceptual Model

2.1 The four altitudes

Layer	Altitude	Name	The question it answers
Layer 1	Regulatory	Regulatory Floor	What is the institution required to do, in which jurisdictions, under which binding authority sources?
Layer 2	Strategic	Strategic Compass	What does the institution choose to do with AI, given its risk appetite, vision and competitive posture?
Layer 3	Operational	Operational Machinery	How does the institution govern the AI systems it has decided to build?
Layer 4	Technical	Technical Substrate	How are those systems engineered so that the governance is real rather than aspirational?

On the name ”Regulatory Floor”. Layer 1 contains more than regulation: law, regulation, supervisory instruments, contractual commitments carrying regulatory consequence, and Sharia Supervisory Board determinations. The layer is therefore defined as **the minimum binding obligation boundary**. ”Regulatory” is shorthand for the layer's function and is not a claim that every source within it is legislation.

doi.org/10.5281/zenodo.22109836

2.2 The canonical diagram

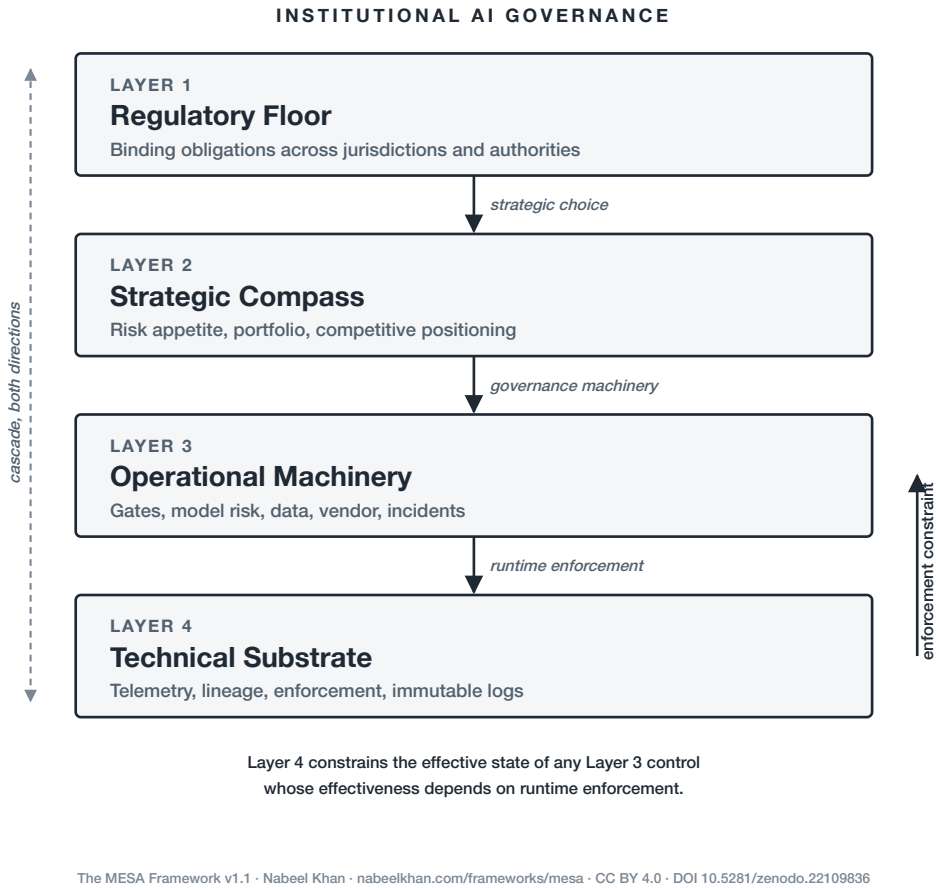


Figure 1: **Figure 1.** The four governance altitudes, the cascade, and the enforcement constraint.

This diagram is also deposited as a standalone vector file, `mesa-four-layers.svg`.

2.3 The governance chain

The chain below is the framework's central pattern. A requirement that does not complete it is not governed, regardless of its documentation status.

The forward path runs from a binding obligation to a reproducible artefact. The reverse path closes the loop: evidence produces findings, findings enter revalidation scope, revalidation changes controls, and control change that cannot be absorbed returns to the strategic altitude as an appetite question. An institution that operates the forward path only has an open loop, and an open loop cannot correct itself. This diagram is also deposited as a standalone vector file, `mesa-governance-loop.svg`.

2.4 Formal statement

Let an institution's governance state be

> G = (L1, L2, L3, L4, C)

where L1 through L4 are the maturity levels of the four altitudes on the scale in Section 7.1, and C is cross-layer coupling integrity, the degree to which the interfaces specified in 5.3 and 4.2 operate without manual reconciliation.

Effective governance capability is a function of all five terms:

doi.org/10.5281/zenodo.22109836

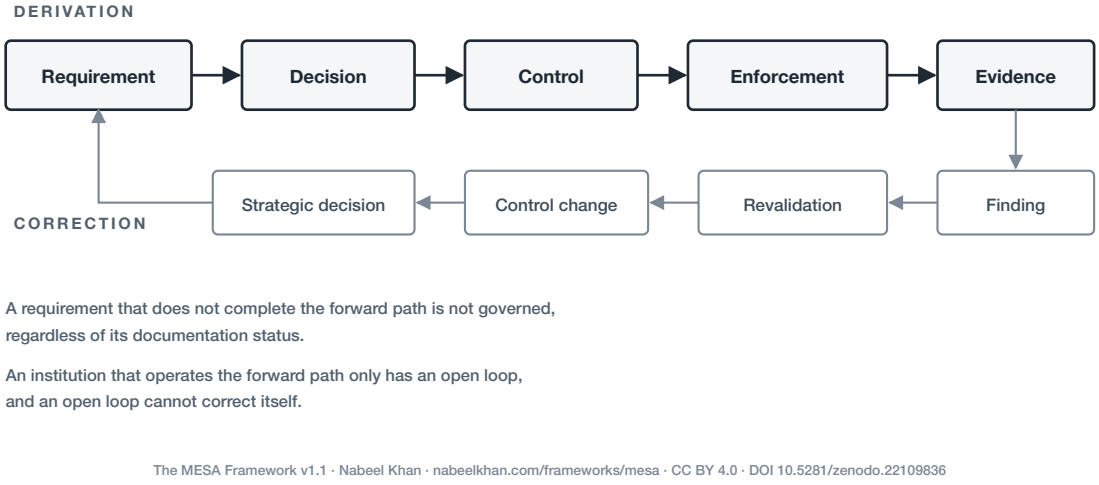


Figure 2: **Figure 2.** The governance chain. The forward path derives evidence from a requirement; the reverse path closes the loop.

> G_effective = f(L1, L2, L3, L4, C)

subject to the enforcement constraint stated in 2.5. MESA does not specify the form of f. It asserts that f is not the arithmetic mean of L1 through L4, and that reporting a single scalar in place of the vector discards the diagnostic information the framework exists to produce. Establishing the form of f empirically is research item 2 in Section 8.3.

2.5 The enforcement constraint

For any control c whose effectiveness depends on runtime technical enforcement:

> L3_effective(c) ≤ L4(c)

Qualification, and it is important. This constraint is not universal across all controls. Controls whose effectiveness does not depend on runtime technical enforcement are not bounded by Layer 4. Board accountability, conflict escalation, committee authority, independent challenge, vendor contract approval and governance reporting are effective as institutional processes and are not capped by substrate capability. The constraint applies to the subset of controls that must hold inside a running system: residency, per-decision disclosure, retention, access control, monitoring and audit-trail reproduction.

An institution shall classify each Layer 3 control as runtime-dependent or not, and record the classification. The constraint applies only to the former. This classification is itself an artefact and is subject to the evidence requirement in 5.4.

2.6 Governance dependency, enforcement dependency and remediation priority

These three orderings are distinct and are frequently conflated.

Governance dependency: L1 → L2 → L3 → L4. Obligations are identified before posture is chosen; posture is chosen before machinery is built; machinery is specified before the substrate that enforces it. This is the order of derivation.

Enforcement dependency: L4 constrains L3. For runtime-dependent controls only, per 2.5. This is the order of constraint and it runs against the order of derivation, which is why the two are frequently confused.

Remediation priority: risk-weighted and dependency-aware. It is **not** lowest-score-first, and it is not ”fix Layer 4 first”. A low Layer 4 score does not mean Layer 4 should be remediated before Layer 1, because an institution that does not know its obligations cannot specify what the substrate must enforce. Remediation order shall be derived from three inputs together: the risk-weighted exposure of the affected systems; the governance

doi.org/10.5281/zenodo.22109836

dependency, so that no layer is remediated ahead of a layer it derives from; and the enforcement constraint, so that operational controls are not declared in force ahead of the substrate that must carry them. Section 7.4 specifies the procedure.

2.7 MESA invariants

Eight statements hold across the framework. They are normative and are restated nowhere else.

1. **Binding obligations are not risk-traded.** A Layer 1 obligation is satisfied or the system does not run. It is not weighed against likelihood and impact.
2. **Strategic choices cannot override Layer 1.** Layer 2 operates inside the boundary, never through it.
3. **Operational controls require named individual ownership.** Accountability vested in a committee is not accountability.
4. **Runtime-dependent controls require runtime enforcement.** A control that must hold inside a running system and is enforced only on paper is not in force.
5. **Evidence shall be reproducible, not reconstructed.** An artefact assembled in response to the request does not satisfy an evidence requirement.
6. **Material changes propagate across all four layers.** Including a recorded determination that a given layer is unaffected.
7. **Cross-pillar interfaces are part of conformance.** Control families that each satisfy their own requirements while failing to exchange artefacts are non-conformant.
8. **A maturity score without evidence is invalid.** A score derived from policy claims rather than operating reality is not a MESA score.

---

3. Relationship to Existing Frameworks

This section determines whether MESA is a contribution or a repackaging. The claim under test is narrow, and it is stated carefully.

The relationship is instantiation, not correction. ISO/IEC 42001 and the NIST AI Risk Management Framework deliberately leave implementation choices to the organization, because both are written to apply across sectors, jurisdictions and organizational forms. That is a design property, not an omission. **MESA instantiates a particular set of those implementation decisions for a defined governance context: regulated institutions operating under plural binding authority sources.** Where this section says a standard ”leaves open” a decision, it means the standard delegates it by design, and MESA supplies one specific instantiation that an institution in this context may adopt.

Every clause number, control number, function identifier and category identifier below was verified against the published standard or the issuing body's own text before it entered this document. Sources and verification notes are in Section 10.

3.1 Mapping to ISO/IEC 42001:2023 at clause level

ISO/IEC 42001:2023, *Information technology. Artificial intelligence. Management system*, specifies requirements for an AI management system [1]. Its requirement clauses run 4 through 10, following the harmonized management-system structure: 4 Context of the organization, 5 Leadership, 6 Planning, 7 Support, 8 Operation, 9 Performance evaluation, 10 Improvement. Annex A carries thirty-eight controls under nine control objectives numbered A.2 through A.10.

Layer 1, Regulatory Floor.

doi.org/10.5281/zenodo.22109836

ISO/IEC 42001 reference	What the clause requires	What it delegates, and what MESA instantiates
4.1 Understanding the organization and its context; 4.2 Understanding the needs and expectations of interested parties; 4.3 Determining the scope of the AI management system	The organization determines its context, the interested parties relevant to the AIMS and their requirements, and the AIMS scope	The standard is jurisdiction-agnostic by design. It does not prescribe a per-system register mapping each AI system to each authority with jurisdiction over it, does not distinguish a binding requirement source from a stakeholder expectation, and supplies no rule for obligations that cannot be simultaneously satisfied. MESA requires the jurisdictional register (5.1, Outputs a), requires a Sharia Supervisory Board to be classified as a binding authority source rather than an interested party where its approval is a deployment precondition, and requires a conflict register with a recorded resolution (5.1, Outputs b)
6.1.2 AI risk assessment; 6.1.3 AI risk treatment	An AI risk assessment process is defined and applied; risks are treated and a Statement of Applicability produced	Regulatory obligation enters as one risk input among others. MESA treats the Layer 1 obligation set as a boundary rather than a risk to be treated, per invariant 1
A.2.3 Alignment with other organizational policies	The AI policy aligns with the organization's other policies	Does not address alignment across supervisory regimes that disagree with each other. MESA requires the conflict register to record the disagreement rather than resolve it silently in favour of the more convenient regime

Layer 2, Strategic Compass.

ISO/IEC 42001 reference	What the clause requires	What it delegates, and what MESA instantiates
5.1 Leadership and commitment; 5.2 AI policy; 5.3 Roles, responsibilities and authorities	Top management demonstrates commitment; an AI policy is established and documented; roles and authorities are assigned	The standard requires a policy. It does not require the institution's risk appetite for AI to be expressed as a board-approved statement with a stated review period, and does not place the appetite decision at a specific level of the organization. MESA places it at the board, non-delegable, and specifies four questions it shall answer (5.2, Outputs a)
6.2 AI objectives and planning to achieve them; A.6.1.2 Objectives for responsible development of AI system; A.9.3 Objectives for responsible use of AI system	AI objectives are established, measurable where practicable, and planned	Does not address external strategic context. MESA requires the AI portfolio to be mapped against the published national or sectoral AI strategy of every jurisdiction of operation, because that mapping determines which use cases receive supervisory tailwind (5.2, Outputs b)
A.2.2 AI policy; A.2.4 Review of the AI policy	The AI policy is documented and reviewed	Review cadence is delegated. MESA requires annual board re-approval of the appetite and a review trigger on any material change to the Layer 1 register

Layer 3, Operational Machinery.

doi.org/10.5281/zenodo.22109836

ISO/IEC 42001 reference	What the clause requires	What it delegates, and what MESA instantiates
8.1 Operational planning and control; 8.2 AI risk assessment; 8.3 AI risk treatment; 8.4 AI system impact assessment	The processes planned in clause 6 are implemented, performed at planned intervals, and their results retained	The standard requires the processes to exist and be documented. It does not require them to be coupled. An institution can satisfy 8.1 through 8.4 with six independent processes that never exchange an artefact. MESA requires four couplings and treats their absence as nonconformance (5.3, Mandatory couplings)
6.1.4 AI system impact assessment	A process for assessing AI system impacts on individuals, groups and society is established	ISO/IEC 42005:2025 provides guidance for performing the assessment [3]. Neither document assigns it to a standing institutional body holding decision authority. MESA routes it through the deployment gate structure so that the assessment has a decision consequence rather than a filing location
7.2 Competence; 7.5 Documented information; A.4.6 Human resources	Competence is determined and evidenced; documented information is controlled	Does not address the standing function. MESA specifies an AI Governance Office as a named institutional system with an accountable lead, and requires accountability to rest with a single executive rather than a committee (5.3, Accountable role)
9.1 Monitoring, measurement, analysis and evaluation; 9.2 Internal audit; 9.3 Management review; 10.2 Nonconformity and corrective action	Performance is evaluated, internally audited, reviewed by management, and nonconformities corrected	Does not address production latency of evidence. MESA requires any Layer 3 artefact for a named production system to be producible within an institution-defined service level without reconstruction (5.3, Evidence requirement)
A.3.2, A.3.3, A.4.2 to A.4.6, A.5.2 to A.5.5, A.6.1.3, A.6.2.2 to A.6.2.8, A.7.2 to A.7.6, A.8.2 to A.8.5, A.9.2, A.9.4, A.10.2 to A.10.4	Roles and concern reporting; resources; impact assessment; life-cycle processes; data; information for interested parties; responsible use; third-party and customer relationships	Collectively the closest Annex A analogue to Layer 3's six pillars. They specify control content, not control architecture. MESA specifies the architecture: which pillar owns which artefact, and which artefact is an input to which other pillar

Layer 4, Technical Substrate.

ISO/IEC 42001 reference	What the clause requires	What it delegates, and what MESA instantiates
A.4.4 Tooling resources; A.4.5 System and computing resources	Tooling and computing resources for AI systems are documented	Documentation of resources, not properties of the running system. MESA requires the architecture to enforce data residency by construction rather than by policy, and requires the residency attestation to be generated by the architecture rather than asserted by a control owner (5.4, Outputs a)
A.6.2.5 AI system deployment; A.6.2.6 AI system operation and monitoring	Deployment and operational monitoring are performed per defined criteria	Monitoring is required; its dimensioning is delegated. MESA requires monitoring scope, metric family, cadence and threshold to be fixed per risk tier and traceable to the Layer 1 obligation or Layer 3 control that motivates them (5.4, Outputs b)
A.6.2.7 AI system technical documentation; A.6.2.8 AI system recording of event logs	Technical documentation is produced; event logs are recorded	Log retention is delegated. MESA derives the retention window from the disclosure obligation the log must satisfy, and requires the audit trail to reproduce the explanation that was shown at decision time rather than regenerate a current one (5.4, Outputs c)

doi.org/10.5281/zenodo.22109836

ISO/IEC 42001 reference	What the clause requires	What it delegates, and what MESA instantiates
A.7.5 Data provenance; A.7.4 Quality of data for AI systems	Provenance and quality of data are addressed	Does not address the coupling to model documentation. MESA requires lineage to feed the model card without manual reconciliation (5.3, Coupling 2)

3.2 Mapping to the NIST AI Risk Management Framework at function and category level

The NIST AI Risk Management Framework 1.0, published as NIST AI 100-1 in January 2023, organizes its Core into four functions: GOVERN, MAP, MEASURE and MANAGE [5]. GOVERN carries categories GOVERN 1 through GOVERN 6, MAP carries MAP 1 through MAP 5, MEASURE carries MEASURE 1 through MEASURE 4, and MANAGE carries MANAGE 1 through MANAGE 4. The framework is voluntary and outcome-stated. It describes conditions that hold in a governed organization rather than mechanisms that produce them.

MESA layer	NIST AI RMF categories and subcategories	What the AI RMF delegates, and what MESA instantiates
Layer 1, Regulatory Floor	GOVERN 1.1 (legal and regulatory requirements involving AI are understood, managed and documented); MAP 1.1 (context-specific laws, norms and expectations are understood and documented); MAP 4.1 (legal risks of components, including third-party data or software)	GOVERN 1.1 states the outcome. It supplies no method for a system under two or more concurrently binding regimes and does not treat an authority whose approval is a precondition but which is not a state regulator. MESA specifies the register, the conflict register and the position of a binding authority source inside the floor
Layer 2, Strategic Compass	GOVERN 1.3 (level of risk management activity based on risk tolerance); GOVERN 2.3 (executive leadership takes responsibility for decisions about risks); MAP 1.3 (mission and goals); MAP 1.4 (business value or context of business use); MAP 1.5 (organizational risk tolerances are determined and documented); MAP 3.1 and MAP 3.2 (benefits and costs examined and documented)	The AI RMF is explicit that it does not supply the tolerance: ”While the AI RMF can be used to prioritize risk, it does not prescribe risk tolerance” (AI RMF 1.0, 1.2.2 Risk Tolerance) [5]. It also does not name the body that owns the decision. MESA names the board, fixes the artefact, fixes the four questions, and fixes the annual cadence
Layer 3, Operational Machinery	GOVERN 1.2, 1.4, 1.5, 1.6, 1.7; GOVERN 2.1, 2.2; GOVERN 4.1, 4.2, 4.3; GOVERN 6.1, 6.2; MAP 2.1 to 2.3; MAP 3.3 to 3.5; MAP 4.2; MAP 5.1, 5.2; MEASURE 1.1 to 1.3; MEASURE 3.1 to 3.3; MEASURE 4.1 to 4.3; MANAGE 1.1 to 1.4; MANAGE 2.1 to 2.4; MANAGE 3.1, 3.2; MANAGE 4.2, 4.3	The Core is a set of outcomes, not an institutional architecture. It does not assign outcomes to standing bodies, does not define deployment gates with entry criteria and rejection paths, and does not require the outcomes to be coupled to each other. MESA specifies the six pillars, the gate structure and the four mandatory couplings
Layer 4, Technical Substrate	GOVERN 1.6 (inventory mechanisms); GOVERN 1.7 (decommissioning and phase-out); MEASURE 2.4 (functionality and behavior monitored in production); MEASURE 2.5 (validity and reliability demonstrated); MEASURE 2.7 (security and resilience); MEASURE 2.9 (the AI model is explained, validated and documented); MEASURE 2.10 (privacy risk); MEASURE 2.11 (fairness and bias evaluated and results documented); MANAGE 4.1 (post-deployment monitoring plans implemented)	MEASURE 2.11 requires fairness and bias to be evaluated and documented and deliberately names no metric or threshold. MESA also declines to mandate universal thresholds, and instead requires that the metric family, cadence, threshold and retention be fixed per risk tier and traced to the obligation that motivates them, so that the choice is inspectable rather than implicit. Section 5.4 gives default metric families

Two structural differences are worth stating precisely.

First, the AI RMF places all four functions at one altitude: an organization applies GOVERN, MAP, MEASURE and MANAGE to a system. MESA places its four layers at four altitudes and asserts a constraint between two of

doi.org/10.5281/zenodo.22109836

them (2.5). **Neither framework expresses the specific cross-altitude dependency MESA proposes**, which is the framework's principal claim to novelty and the claim most exposed to falsification (8.2).

Second, the AI RMF's GOVERN function spans what MESA separates into Layers 2 and 3. A consequence is that a GOVERN-level finding does not by itself indicate whether the remedy is a board decision or an office build.

3.3 The contribution, stated once

Primary contribution: a four-altitude diagnostic model for institutional AI governance, in which maturity is reported as a vector across altitudes rather than as a single organizational score.

Supporting mechanisms, which operate the architecture and are not independent contributions:

1. **Layer separation**, which makes altitude mismatch visible.
2. **Cross-layer cascade** (4.2), the propagation mechanism.
3. **The enforcement constraint** (2.5), the constraint mechanism.
4. **Mandatory inter-control couplings** (5.3), the interface mechanism.
5. **The evidence-based maturity vector** (Section 7), the measurement mechanism.

Domain specialization: plural binding authority sources, including religious-law authorities with binding approval power.

3.4 What the reference frameworks provide that MESA does not duplicate

MESA is not a substitute for either document and an institution should hold both. ISO/IEC 42001 supplies the certifiable management-system structure, the Statement of Applicability discipline, and the auditable improvement cycle, none of which MESA restates [1]. ISO/IEC 23894:2023 supplies AI-specific risk management guidance [2]. ISO/IEC 42005:2025 supplies the method for conducting an AI system impact assessment, which MESA requires but does not specify [3]. The NIST AI RMF supplies the trustworthiness characteristics vocabulary and a mature outcome taxonomy, and its Generative AI Profile supplies generative-specific risk treatment [5][6]. An institution seeking certification should work to ISO/IEC 42001 and use ISO/IEC 42006:2025 to select an assessment body [4].

---

4. Structural Properties (Normative)

4.1 Concurrency

The layers shall be operated concurrently, not sequentially. They are not phases of a programme and shall not be sequenced as such. An institution that treats them as a one-time checklist will be governing a state of the world that has already changed.

4.2 Cascade

A **material change** as defined in 1.2, arising at any layer, shall be propagated through the other three within the same governance cycle, and the propagation shall be recorded. The record shall include a determination that a given layer is unaffected, where that is the conclusion; an absent record and a determination of ”no impact” are not equivalent and shall not be treated as such.

A new instrument entering Layer 1 changes the Layer 2 appetite question, the Layer 3 control set and the Layer 4 instrumentation. A new capability at Layer 4 may permit a tighter Layer 3 protocol, which may reshape the Layer 2 appetite. Cascade therefore runs in both directions.

4.3 The enforcement constraint

As specified in 2.5, with its qualification. Where the substrate cannot enforce a runtime-dependent control, the control is not in force regardless of its documentation status. The institution **shall** record documented inability rather than assert compliance. A documented-inability record shall name the missing capability, the compensating control in place, the accountable owner for closing it, and the target date.

Documented inability is a defensible posture. Concealed inability is not, and the difference is visible at examination.

doi.org/10.5281/zenodo.22109836

4.4 No fifth layer

Where a Sharia Supervisory Board holds binding authority, that authority reaches into Layers 1, 3 and 4 and **shall not** be modelled as a fifth layer or as an overlay on Layer 1. It is a binding authority source inside Layer 1 (5.1), a validation track and notification path inside Layer 3 (5.3), and, where the institution has adopted such a scheme, a data-certification chain inside Layer 4 (5.4). An institution that staffs Sharia governance as a parallel function with limited integration to the Layer 3 pillars produces a parallel record that the board can audit and the institution cannot operate against.

---

5. The Four Layers (Normative)

5.1 Layer 1: Regulatory Floor

Definition. The minimum binding obligation boundary: the set of obligations the institution shall satisfy to operate its AI systems lawfully and licitly across every jurisdiction it operates in and under every binding authority source whose determination is a precondition of deployment.

Purpose. To fix the boundary. Layer 1 states what the institution may not do irrespective of strategic preference or commercial pressure. An institution operating only at Layer 1 will pass the examinations it is invited to and forfeit the competitive positions it is contested in, which is why Layer 1 is necessary and insufficient.

Inputs.

- The jurisdictional perimeter: every jurisdiction in which the institution offers services, holds data, or is otherwise subject to supervision.
- The statutes, regulations, supervisory instruments and sectoral expectations of each, including data protection law [12][13][15], automated-decision rules [12][14], model risk guidance [10][11] and residency requirements.
- Where applicable, the rulings and standing determinations of the Sharia Supervisory Board, within the governance architecture set by IFSB-10 [16], IFSB-31 [17] and AAOIFI GS 1 (Revised 2024) [18].
- Contractual commitments carrying regulatory force, such as data-processing agreements and residency undertakings.
- Where the institution operates in or into the European Union, Regulation (EU) 2024/1689 as amended [7][8][9].

Outputs. a. **The jurisdictional register.** A current mapping of every AI system in the inventory to every binding authority source with jurisdiction over it and to the specific obligation each imposes on that system. Each entry shall carry the metadata specified in Section 9. The register shall carry an as-of date and a named owner per jurisdiction. b. **The conflict register.** A record of obligations that cannot be simultaneously satisfied on the same system, with the architectural or legal resolution adopted and the residual exposure accepted. Recording the conflict is required. Resolving it silently in favour of the more convenient regime is a non-conformance. c. **The obligation-to-control trace.** For each obligation, the Layer 3 control and, where the control is runtime-dependent per 2.5, the Layer 4 enforcement mechanism that satisfies it, together with the evidence artefact that demonstrates operation. This trace is the instantiation of the governance chain in 2.3.

Accountable role. A single named executive, typically the General Counsel or Chief Compliance Officer, is accountable for the register's currency and completeness. Named per-jurisdiction leads are responsible for their entries. Where a Sharia Supervisory Board holds binding authority, that authority is independent and non-delegable, and no executive may waive it.

Evidence requirement. The institution shall be able to produce, on request: the current register with its as-of date; the conflict register; the obligation-to-control trace for any named system; and, where applicable, the Sharia Supervisory Board determination on file for any Sharia-relevant system. The register's review cadence shall be no longer than the publication cycle of the fastest-moving authority in the perimeter. A register whose as-of date predates an authority's most recent instrument is a finding in itself.

5.2 Layer 2: Strategic Compass

Definition. The institution's deliberate choices about which AI it will build, at what level of accepted risk, and to what competitive end, made inside the Layer 1 boundary.

doi.org/10.5281/zenodo.22109836

Purpose. To convert a boundary into a direction. An institution without an explicit appetite produces one implicitly through accumulated ad-hoc decisions, and an implicit appetite is not defensible under inquiry because nobody approved it.

Inputs. The Layer 1 register and conflict register; institutional strategy and risk appetite for non-AI risk; the published national or sectoral AI strategies of every operating jurisdiction; the current AI portfolio; the institution's capability position; the current Layer 3 and Layer 4 maturity readings.

Outputs. a. **A board-approved AI risk appetite statement**, re-approved at least annually, answering four questions at minimum:

1. Which classes of AI use case will the institution invest in, and which will it exclude?
2. What level of model risk is acceptable in each class?
3. What level of vendor and model concentration is acceptable in AI services?
4. What is the institution's posture on generative AI in customer-facing contexts? b. **A portfolio-to-strategy map** relating each material AI investment to the national or sectoral AI strategy of the jurisdiction it is deployed in, so that supervisory tailwind and headwind are visible before commitment rather than after. c. **An explicit governance positioning decision**, recording whether the institution treats governance capability as a compliance cost or as a capability it intends to compete on, and what follows operationally from that choice.

Accountable role. The board. This accountability is non-delegable and shall not be assigned to a technology committee or a risk committee.

Evidence requirement. Minuted board approval of the appetite statement dated within the preceding twelve months; the portfolio-to-strategy map; and the record of use cases declined or conditioned against the appetite. The last item is the operative test. An appetite statement that has never caused a proposal to be declined or materially conditioned is not binding on the institution, and a reporting period with zero such records shall be treated as evidence that Layer 2 is documentary rather than operative.

5.3 Layer 3: Operational Machinery

Definition. The standing institutional machinery that converts Layer 2 intent into Layer 1 compliance for every AI system across its full lifecycle.

Relation to Layer 4. Layers 3 and 4 are the same controls observed from two altitudes. A control exists at Layer 3 as a documented, owned, auditable process. A runtime-dependent control also exists at Layer 4 as a property of a running system. Where the two diverge, Layer 4 governs the effective state, by 2.5.

The six pillars. Layer 3 shall comprise six pillars. Each is a control family with a named owner and a defined artefact set.

Pillar	Name	Principal artefacts
1	Governance operating model	Accountability matrix; deployment gate records; committee charter, cadence and minutes; three-lines allocation for AI [19]
2	Governance office	Office charter; staffing and competence record; technology stack; standing decision authority
3	Model risk management	Model inventory with risk classification; validation reports; model cards; revalidation schedule; findings register with escalation tiers
4	Data governance	Data classification applied to AI-relevant assets; lineage; quality measures; anonymization records [21]
5	Vendor risk	Vendor risk register with classification; due diligence records; contract terms including change notification and residency; exit plan
6	Incident response	Severity classification; runbooks per severity tier; incident log; regulatory and, where applicable, Sharia Supervisory Board notification pathways; post-incident review records

Pillar 1 is not the AI Governance Operating Model. The framework of that name is catalogued as REG-07 of the Defensible AI Framework Registry, https://doi.org/10.5281/zenodo.22170112, which places it at the Strategic Compass because that is where an institution chooses the structure it grants and the decision rights it assigns.

doi.org/10.5281/zenodo.22109836

Pillar 1 is the Layer 3 control family in which that structure produces records. Authority is constituted at Layer 2 and evidenced at Layer 3, which is the cascade of 4.2 rather than a disagreement about altitude. Where this specification and the registry describe the same framework, the registry governs its place in the architecture and this specification governs what MESA requires.

Where the institution operates under a Sharia Supervisory Board, pillar 4 additionally carries the data-certification chain specified in Appendix B, which is an institution-specific scheme and is not a generic requirement of this framework.

Mandatory couplings. The six pillars shall exchange artefacts automatically. Four couplings are required, and a pillar set that satisfies each pillar's own requirements while failing these couplings is non-conformant, per invariant 7.

1. **Classification to gate.** The model risk classification from pillar 3 shall determine the deployment gate path and evidence set in pillar 1, without the governance committee re-deriving the classification.
2. **Lineage to model card.** The data lineage from pillar 4 shall populate the corresponding model card sections in pillar 3 without manual reconciliation.
3. **Vendor classification to escalation.** The vendor risk classification from pillar 5 shall determine the incident escalation path in pillar 6 when a vendor-originated incident is detected.
4. **Post-incident findings to revalidation scope.** Findings from pillar 6 post-incident review shall enter the scope of the next revalidation in pillar 3 for every affected model. This coupling closes the reverse path of the governance chain in 2.3.

Deployment gates. No system shall reach production without traversing a defined gate sequence in which every gate carries five components: entry criteria, a named approval authority, a required evidence set, exit criteria expressed as approve, approve with conditions or reject, and a defined rejection path. Where a Sharia Supervisory Board holds binding authority, its sign-off shall be a component of the validation gate rather than a parallel process, and the validation authority shall not be able to approve a Sharia-relevant system without it.

Control classification. Each control shall be classified as runtime-dependent or not, per 2.5, and the classification shall be recorded and reviewed at each material change.

Accountable role. A single named executive, commonly the Chief Risk Officer. The accountability shall not be vested in a committee. The head of the governance office shall hold direct authority for routine governance decisions, with escalation to the accountable executive for material ones.

Evidence requirement. Layer 3 is the evidence layer, so its requirement is stated as a production test rather than an existence test. For any named production AI system, the institution shall be able to produce the current validation report, the risk classification and its basis, the deployment gate record, the applicable vendor file and the incident history **within a service level the institution has defined and recorded as appropriate to its regulatory and risk environment.**

> **Twenty-four hours is the MESA reference value.** An institution shall adopt it unless a stricter requirement applies from a binding authority source, or unless it records a rationale for a different value. The reference value exists to make the requirement testable, not to assert that twenty-four hours is correct for every portfolio.

Artefacts assembled retrospectively in response to the request do not satisfy this requirement, per invariant 5, and an institution should test the requirement by unannounced sampling rather than by scheduled rehearsal.

5.4 Layer 4: Technical Substrate

Definition. The engineering that makes runtime-dependent Layer 3 controls enforceable inside the systems themselves.

Inputs. The Layer 1 obligations that must hold at runtime, specifically residency, disclosure, retention and access; the Layer 3 risk tier, control set and runtime-dependence classification per system; the deployed architecture and its constraints.

Outputs. a. **Architecture that enforces residency by construction.** Data residency shall be honoured by architecture rather than by policy and manual enforcement, and the residency attestation shall be generated by the architecture rather than asserted by a control owner. The architectural pattern chosen, whether isolated per-jurisdiction deployment, federation across jurisdictions, or a regional hub, is a Layer 4 decision with cascading Layer 3 consequences and shall be recorded as an architecture decision with its alternatives and rationale, in the

doi.org/10.5281/zenodo.22109836

sense of an established architecture framework such as TOGAF [20]. b. **Monitoring dimensioned by risk tier.** Monitoring shall cover distributional drift, fairness, and outcome tracking against prediction, at a scope, cadence and threshold fixed per risk tier and traceable to the obligation or control that motivates it. This specification does not mandate universal thresholds, because a threshold that is correct for one portfolio is wrong for another. It requires that the choice be explicit, recorded and inspectable. Default metric families, which an institution should calibrate rather than adopt unexamined: population stability index and the Kolmogorov-Smirnov statistic for distributional drift, with the conventional bands of below 0.1 stable, 0.1 to 0.2 investigate, and above 0.2 act; demographic parity, equalized odds and calibration for fairness, with significance testing; and actual-versus-predicted comparison at a window matched to the outcome's realization lag. Infrastructure observability is not monitoring in this sense: it reports that the service responded, not whether the decision is defensible. c. **Per-decision explainability and a reproducible audit trail.** Where an obligation requires an explanation to a person subject to an automated decision, the institution shall generate and retain the explanation artefact per decision, for a retention window derived from that obligation rather than from storage convenience. The audit trail shall be able to reproduce, for any named production decision, the input record, the model version, the output, and the explanation that was shown at the time. Regenerating a current explanation for a historic decision does not satisfy this requirement and shall not be represented as satisfying it. d. **Security and robustness proportionate to tier.** Encryption in transit and at rest; key management, with customer-managed or institution-managed key options for the highest tier; adversarial robustness testing for high-risk models at development and at revalidation; and, for services built on large language models, prompt-injection and output-handling defences.

Accountable role. A single named executive on the technology side, commonly the Chief Information Officer, Chief Technology Officer or Chief Data and Analytics Officer, jointly answerable with the Layer 3 accountable executive for any runtime-dependent control the substrate cannot enforce.

Evidence requirement. Monitoring coverage reported by risk tier rather than in aggregate; the alert-to-action record showing what was done when a threshold was crossed; a reproduced decision audit trail for a decision **sampled at random by the requester rather than nominated by the institution**; and a residency attestation with its generation method stated. Where any runtime-dependent control cannot be enforced by the substrate, the documented-inability record required by 4.3.

---

6. Failure Taxonomy (Normative for incident classification)

Each class names the altitude at which the chain in 2.3 broke. An institution shall classify governance incidents and audit findings against this taxonomy, because the class determines which layer owns the remedy.

Class	Name	Definition	Owning layer
F1	Boundary failure	An applicable obligation was not identified	Layer 1
F2	Decision failure	A strategic choice violated or disregarded an identified obligation	Layer 2
F3	Control failure	A required control does not exist, or exists and did not operate	Layer 3
F4	Interface failure	Two controls exist and operate, but do not exchange a required artefact	Layer 3, couplings
F5	Enforcement failure	The substrate cannot enforce a runtime-dependent control	Layer 4
F6	Evidence failure	The control may have operated, but the evidence cannot be reproduced	Layer 3 and Layer 4 jointly
F7	Propagation failure	A material change occurred without the cascade required by 4.2	Cross-layer

F6 is the class most often misclassified as F3. An institution that cannot produce evidence frequently concludes the control was absent, and rebuilds a control that was in fact operating. The distinction is diagnostic and determines whether the remedy is a control build or an instrumentation build.

---

doi.org/10.5281/zenodo.22109836

7. Assessment

7.1 The maturity scale

Five levels, applied per layer rather than as one overall grade, because institutions rarely climb the four layers in step.

Level	Name	Observable state
1	Ad Hoc	No formal governance. Each initiative is run by the team that proposed it. No centralized AI inventory
2	Initial	Policies and some committees exist. Execution is inconsistent. Documentation is produced for new initiatives and not retrofitted. Layers operate in silos
3	Defined	Documented processes exist per Layer 3 pillar and are followed for most production systems. Cross-layer references work. The institution can articulate its own gaps without external discovery
4	Managed	Metrics-driven. Every pillar has named indicators tracked, trended and reported to the board. Gaps are identified and closed before they produce incidents
5	Optimized	Strategic and predictive. Governance is a market signal. The institution contributes to the standards and supervisory expectations it operates under

7.2 The instrument, and this document's dependency on it

Assessment is performed with a fifty-question instrument distributed across the four layers at twelve to thirteen questions per layer. Each question carries five anchors, one per level, and each anchor shall be expressed as an observable state rather than as a judgement. A question whose anchors cannot be evidenced is not a maturity question and shall not appear in the instrument.

This document specifies the assessment architecture. It does not contain the instrument. The complete fifty-question instrument with all anchors is specified as a separate companion specification, in preparation at the date of this version, and a MESA assessment is conformant only when performed with that instrument or with a documented instrument that satisfies the architecture in this section. Four representative questions appear in Appendix A to make the anchor pattern concrete. **An institution shall not represent an assessment as MESA-conformant on the basis of Appendix A alone.**

7.3 Scoring

Three scoring rules. These bind every scorer, human or automated, and departure from any of them invalidates the profile.

1. **Score against operating reality, not against policy claims**, per invariant 8.
2. **Score conservatively at boundaries.** Where a score sits between two levels, the lower is recorded.
3. **Score by triangulation.** Each layer's questions shall be answered independently by at least two parties, the layer owner and an independent reviewer. Where the two disagree, the lower score is recorded and the disagreement is retained as a finding.

Reported statistics, and why the mean alone is insufficient. An arithmetic mean across a layer's questions can conceal a disqualifying deficiency. A Layer 3 whose question scores are 3, 3, 3, 3 and 1 has a mean of 2.6, which rounds to Level 3 while carrying a control at Level 1. For governance, weakest-link effects frequently matter more than average performance.

A layer score shall therefore be reported as three values, not one:

> **L_n = (mean, minimum, critical-control floor)**

where the **critical-control floor** is the lowest score among the questions the institution has designated critical for that layer. Designation of critical questions shall be recorded in advance of scoring and shall not be revised after scores are known. A layer reported as ”Layer 3 = 3.2, minimum 1, critical-control floor 1” communicates something a single rounded integer cannot.

doi.org/10.5281/zenodo.22109836

Output. A four-element profile vector carrying all three statistics per layer, its as-of date, the identity of both scoring parties, and the coupling integrity term C from 2.4 reported separately. A conformance claim published without the vector is the single grade this framework exists to replace.

7.4 From profile to remediation sequence

Remediation order shall be derived by the following procedure, which implements 2.6.

1. **Identify disqualifying floors.** Any layer whose critical-control floor is 1 is addressed before any optimization elsewhere, irrespective of its mean.
2. **Respect governance dependency.** No layer is remediated ahead of a layer it derives from. Specifically, Layer 1 gaps are closed before Layer 2 posture is revised, because an appetite set against an incomplete obligation set is not a decision the board can defend.
3. **Apply the enforcement constraint.** Where a Layer 3 control is runtime-dependent and the corresponding Layer 4 capability is absent, the Layer 3 remediation is not complete until the Layer 4 capability exists or a documented-inability record is in force.
4. **Weight by risk.** Within the ordering established by steps 1 to 3, sequence by the risk-weighted exposure of the affected systems.
5. **Respect intra-Layer-3 dependency.** Vendor risk depends on a working model risk intake; model risk depends on a working data governance baseline; incident response depends on all of them.

This procedure is **not** lowest-score-first, and it is **not** ”remediate Layer 4 first”. Both readings are incorrect and both have been observed.

7.5 Conformance

An institution conforms to this specification when all of the following hold and are evidenced:

1. All four layers are operated concurrently, with a recorded cascade for every material change (4.1, 4.2).
2. Each layer has a single named accountable role at the altitude this specification requires (5.1 to 5.4).
3. Each layer's evidence requirement is met under the production test stated for it, not under a scheduled rehearsal.
4. The four Layer 3 couplings operate without manual reconciliation (5.3).
5. Every runtime-dependent control the substrate cannot enforce is carried as a documented-inability record rather than as an asserted control (4.3).
6. Controls are classified as runtime-dependent or not, and the classification is current (2.5, 5.3).
7. A per-layer maturity profile exists, is dated, reports all three statistics per layer, and was produced under the three scoring rules in 7.3 using a conformant instrument per 7.2.

What a conformance claim does not mean. It is not a certification; no accredited body assesses against this specification. It is not a statement of regulatory compliance; compliance is determined by supervisors against their own instruments. It is not transferable across time; a conformance claim is valid only as of the date of the profile that supports it, and an institution should re-state it at least annually.

7.6 Supersession of the Governance Maturity Model

The Governance Maturity Model published in *AI Governance and Compliance Frameworks for the Middle East: The Enterprise Playbook* [22] is **superseded** by the evidence-based maturity profile specified in this section.

The two instruments answer the same question and shall not be operated in parallel. The profile supersedes because it reports per altitude rather than per organization, and because each of its levels carries an evidence requirement that can be tested rather than asserted.

Institutions holding a prior assessment under the Governance Maturity Model MAY map their result using the table below. **The mapping is informative, not normative.** A mapped result indicates a starting position and does not constitute an assessment under this specification, because the prior model did not require per-layer evidence.

Prior level, Governance Maturity Model	Indicative profile	What must be established before the mapped position is asserted
1, Initial	[1,1,1,1]	Nothing. The mapping holds

doi.org/10.5281/zenodo.22109836

Prior level, Governance Maturity Model	Indicative profile	What must be established before the mapped position is asserted
2, Developing	[2,2,1,1]	Evidence that Regulatory Floor obligations are registered and mapped to owners
3, Defined	[3,3,2,1]	Evidence of a chartered mandate and documented decision rights
4, Managed	[4,3,3,1]	Evidence of operating gate records and completed validations
5, Optimized	[4,4,4,1]	Evidence of runtime enforcement, without which the enforcement constraint caps the effective state

The fourth position is 1 in every mapped row, and that is deliberate. The prior model did not assess the Technical Substrate independently, so no substrate maturity can be inferred from a prior result. Under the enforcement constraint at 2.5 and 4.3, the effective state of every runtime-dependent control is bounded by the substrate, which means **a mapped result is an upper bound on the institution's documented posture and says nothing about its enforced one.** Establishing the fourth position requires a substrate assessment the prior model did not perform.

That asymmetry is the reason for the supersession rather than an artifact of it.

---

8. Limitations, Falsification and Research Agenda

8.1 Known limitations

It assumes institutional discipline is the binding constraint. MESA addresses institutions whose governance gap is organizational rather than technical. An institution without the engineering capability to instrument its systems has a Layer 4 capability problem this framework describes but does not solve.

It operates at institutional altitude. Team-level practice is out of scope per 1.4.

Layer 1 is calibrated to a specific regulatory architecture. Plural authorities, active supervisory examination, and in some institutions a binding religious-law authority. In a single-authority jurisdiction with no examination culture, parts of Layer 1 degenerate.

It does not predict supervisory specifics that have not been published. Section 9 exists because of this.

It does not address whether to deploy. Per 1.4 item 1.

It assumes the institution wants to do the work. A framework cannot supply motivation.

8.2 What has not been tested

Stated plainly, because a specification that omits this section is asking to be trusted rather than examined.

1. **No controlled comparison exists.** No study compares institutions that implemented MESA against matched institutions that did not. Every claim in 3.3 is a design claim.
2. **Inter-rater reliability of the instrument is unmeasured.** Two competent assessors scoring the same institution may produce different profile vectors. The triangulation rule in 7.3 is designed to mitigate this and has not been shown to measure or bound it.
3. **The implementation profile timing is a planning heuristic.** The window in Appendix C derives from practice and from disclosed transformation patterns, not from a measured sample with a stated variance.
4. **The enforcement constraint is an architectural assertion.** That Layer 4 bounds the effective state of runtime-dependent Layer 3 controls is stated as a structural property. It has not been demonstrated by measurement.
5. **Portability of Layers 2 through 4 outside MENA financial services is a design claim**, not evidenced by a published application in another sector or region.
6. **Self-assessment inflation is unquantified.** The three scoring rules exist because self-assessment is expected to inflate. Their effectiveness has not been measured against independent assessment of the same institutions.

doi.org/10.5281/zenodo.22109836

7. **The four mandatory couplings have not been cost-benefit tested.** They are asserted to prevent evidence-production failure. Neither the prevention nor its cost has been measured.
8. **The form of f in 2.4 is unspecified and unmeasured.** MESA asserts that effective governance capability is not the mean of the four layer scores. It does not establish what it is.
9. **The critical-control floor has not been shown to predict better than the mean.** It is introduced on the argument that weakest-link effects matter in governance, which is reasoning, not evidence.

8.3 What would invalidate the framework

1. Evidence that institutions with high Layer 3 maturity and low Layer 4 maturity sustain enforceable runtime-dependent controls at the same rate as institutions high in both would falsify the enforcement constraint (2.5) and would remove the sequencing instruction in 7.4.
2. Evidence that a single overall maturity grade predicts supervisory findings, incident frequency or remediation cost as well as or better than a per-layer vector would remove the case for per-layer scoring, which is the framework's principal claim.
3. A demonstration that the four mandatory couplings add cost without reducing evidence-production failure would make the couplings a recommendation rather than a requirement.
4. A supervisory regime that treats a Sharia Supervisory Board determination as advisory rather than binding would, for institutions under that regime, move the board out of Layer 1 and into Layer 2, and 4.4 would not hold there.
5. Evidence that the boundary between Layers 2 and 3 is not where institutions actually fail, and that observed failures cluster inside a single layer rather than at the interfaces between them, would indicate that the layer boundaries are drawn in the wrong places.
6. Evidence that the failure taxonomy in Section 6 does not partition real incidents cleanly, in that a material share of incidents cannot be assigned to exactly one class, would indicate that the classes are not the natural joints of the phenomenon.
7. Evidence that the critical-control floor systematically misclassifies institutions relative to independent supervisory assessment would remove it from 7.3 in favour of the mean.

Each is measurable in principle. None has been measured. The licence on this document exists partly to make independent measurement possible without permission.

8.4 Research agenda

An invitation, not a roadmap. Items 1 to 4 are the prerequisites for treating MESA as an instrument rather than a design.

1. **Inter-rater reliability.** Two or more independent assessors, same institutions, measured agreement per layer.
2. **Construct validity.** Do the four layers measure four distinct constructs, or do they collapse under factor analysis?
3. **Criterion and predictive validity.** Does the profile vector predict supervisory findings, incident frequency or remediation cost, and does it predict better than a single grade?
4. **The form of f.** Establish empirically how the four layer scores and the coupling term combine into effective capability.
5. **Coupling effectiveness.** Do the four couplings reduce evidence-production failure, and at what cost?
6. **The enforcement constraint.** Does low Layer 4 capability predict failure of runtime-dependent Layer 3 controls?
7. **Critical-control floor versus mean.** Which better predicts external assessment outcomes?
8. **Remediation-cost optimization.** Does the 7.4 sequence produce lower total remediation cost than alternatives?
9. **Cross-sector portability.** Apply Layers 2 to 4 in a regulated non-financial sector.
10. **Cross-jurisdiction portability.** Reconstruct Layer 1 for a non-MENA geography and test whether Layers 2 to 4 survive unchanged.

Researchers intending any of these are invited to contact the author through the ORCID record on the title page. The author will supply the assessment instrument and, subject to institutional consent, introductions.

doi.org/10.5281/zenodo.22109836

9. Regulatory Snapshot Discipline (Normative)

Every external regulatory reference in the Layer 1 register **shall** carry the following ten fields. A reference lacking any of them is incomplete, because a register that cannot state when it was last verified cannot be relied upon at examination.

Field	Purpose
Jurisdiction	The geography whose authority the obligation arises under
Authority	The named binding authority source
Instrument	The specific statute, regulation, supervisory letter, standard or determination
Version or amendment state	Which text is being relied on
Date of instrument	When it was issued
Effective date	When it entered force
Application date	When obligations begin to bind, where this differs from the effective date
Superseded instrument	What it replaced, where applicable
Last verified date	When the institution last confirmed the entry against the source
Source URL or citation	Where the text was read
MESA relevance	Which layer, control and evidence artefact it drives

The application date and the effective date are frequently different, and conflating them is a recurring source of error. Section 10 reference [9] documents an instance in which an obligation applied from one date while supervisory enforcement of it began eighteen months later, and in which the issuing body's own guidance rendered the enforcement date inconsistently across two sentences on the same page.

---

10. References

Regulatory and standards citations were verified against the issuing body's published text, or against the standing citation reference maintained for the source volume, before entering this document. Web resources were accessed on 26 August 2026. Where a standard is available only under licence, the citation records the catalogue entry and the structural facts were triangulated across independent published sources; those instances are noted.

Standards

[1] ISO/IEC 42001:2023, *Information technology. Artificial intelligence. Management system*. International Organization for Standardization and International Electrotechnical Commission, Geneva, December 2023. Catalogue entry: https://www.iso.org/standard/42001. *Note: clause and Annex A structure cited in Section 3.1 was triangulated across three independent published clause-by-clause listings; the standard text itself is available only under licence from ISO or a national member body.*

[2] ISO/IEC 23894:2023, *Information technology. Artificial intelligence. Guidance on risk management*. ISO/IEC, Geneva, 2023.

[3] ISO/IEC 42005:2025, *Information technology. Artificial intelligence (AI). AI system impact assessment*. ISO/IEC, Geneva, 2025. Catalogue entry: https://www.iso.org/standard/42005.

[4] ISO/IEC 42006:2025, *Information technology. Artificial intelligence. Requirements for bodies providing audit and certification of artificial intelligence management systems*. ISO/IEC, Geneva, 2025. Catalogue entry: https://www.iso.org/standard/42006.

Frameworks and guidance

[5] National Institute of Standards and Technology. *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. NIST AI 100-1. Gaithersburg, MD, January 2023. https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf. Core functions, categories and subcategories cited in Section 3.2 verified against the NIST AI Resource Center rendering of Section 5, *AI RMF Core*: https://airc.nist.gov/airmf-resources/airmf/5-sec-core/. Risk-tolerance quotation verified verbatim at Section 1.1.2, *Risk Tolerance*: https://airc.nist.gov/airmf-resources/airmf/1-sec-risk/.

doi.org/10.5281/zenodo.22109836

[6] National Institute of Standards and Technology. *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*. NIST AI 600-1. Gaithersburg, MD, 26 July 2024. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf.

Legislation and supervisory instruments

[7] Regulation (EU) 2024/1689 of the European Parliament and of the Council laying down harmonised rules on artificial intelligence (Artificial Intelligence Act). Official Journal of the European Union.

[8] Regulation (EU) 2026/1744 of the European Parliament and of the Council, commonly cited as the Digital Omnibus on AI, amending Regulation (EU) 2024/1689, Regulation (EU) 2018/1139 and Regulation (EU) 2023/1230. Published in the Official Journal on 24 July 2026; entered into force 27 July 2026. https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng.

[9] Amended application dates under [8]: stand-alone high-risk AI systems under Annex III of Regulation (EU) 2024/1689 apply from 2 December 2027; AI embedded in products regulated under Annex I from 2 August 2028; Article 50 transparency obligations remain applicable from 2 August 2026, with a grace period to 2 December 2026 for the Article 50(2) marking duty on systems placed on the market before that date. The Article 4 AI-literacy obligation was amended by [8] rather than deferred or repealed, and it carries two distinct dates. **It has been in application since 2 February 2025. National market surveillance authorities begin supervising and enforcing it from 2 August 2026.** The duty continues to sit on providers and deployers, who shall take measures to support the development of AI literacy among their staff and among those operating systems on their behalf. What the amendment changed is that the duty is now an obligation of means rather than of result: the text does not require providers or deployers to guarantee any specific level of AI literacy in any individual, and a further paragraph tasks the Commission and the Member States with supporting those efforts, with particular regard to small and medium-sized enterprises. *Verifier note: the European Commission's AI literacy questions-and-answers page renders the enforcement start as both 2 August 2026 and 3 August 2026 in different sentences. This document uses 2 August 2026, which is the AI Act's general date of application and the date carried by the Commission's own sentence on market surveillance authorities.* https://digital-strategy.ec.europa.eu/en/faqs/ai-literacy-questions-answers.

[10] Board of Governors of the Federal Reserve System, Office of the Comptroller of the Currency and Federal Deposit Insurance Corporation. Supervisory Letter SR 26-2, *Revised Guidance on Model Risk Management*, 17 April 2026. Supersedes SR 11-7 (4 April 2011) and SR 21-8 (9 April 2021). https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm. Guidance attachment: https://www.federalreserve.gov/supervisionreg/srletters/SR2602.pdf. *Footnote 3 of the guidance places generative AI and agentic AI models outside its scope, and it shall not be cited as an AI-specific instrument.*

[11] Office of the Superintendent of Financial Institutions (Canada). *Guideline E-23: Model Risk Management (2027)*. Final guideline published 11 September 2025; effective 1 May 2027 for federally regulated financial institutions. https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/guideline-e-23-model-risk-management-2027.

[12] United Arab Emirates. Federal Decree-Law No. 45 of 2021 on the Protection of Personal Data. Article 18 establishes a right to object to decisions issued with respect to automated processing that have legal consequences or seriously affect the data subject, including profiling. *Note: the federal Executive Regulations were not yet gazetted at the date of this document; no penalty schedule is cited here for that reason.*

[13] Kingdom of Saudi Arabia. Personal Data Protection Law, Royal Decree M/19 of 2021, as amended in 2023, together with its Implementing Regulations issued by the Saudi Data and Artificial Intelligence Authority. Automated-decision obligations sit in the Implementing Regulations and are cited generically here rather than pinned to an article number.

[14] Dubai International Financial Centre. Data Protection Regulations, Regulation 10, *Processing Personal Data through Autonomous and Semi-autonomous Systems*, in force 1 September 2023. https://www.difc.com/business/registrars-and-commissioners/commissioner-of-data-protection/regulation-10.

[15] Arab Republic of Egypt. Law No. 151 of 2020 on Personal Data Protection, together with its Executive Regulations issued by Ministerial Decree 816 of 2025.

Sharia governance

[16] Islamic Financial Services Board. IFSB-10, *Guiding Principles on Shari'ah Governance Systems for Institutions Offering Islamic Financial Services*. Kuala Lumpur, December 2009. https://www.ifsb.org/wp-content/uploads/2023/10/IFSB-10-December-2009_En.pdf.

doi.org/10.5281/zenodo.22109836

[17] Islamic Financial Services Board. IFSB-31, *Guiding Principles for Effective Supervision of Shari'ah Governance*. Kuala Lumpur, July 2025. https://www.ifsb.org/wp-content/uploads/2025/07/IFSB-31-Guiding-Principles-for-Effective-Supervision-of-Shariah-Governance.pdf. **IFSB-31 builds on IFSB-10 and does not replace it.**

[18] Accounting and Auditing Organization for Islamic Financial Institutions. Governance Standard GS 1 (Revised 2024), *Shari'ah Governance Framework*, together with GS 19 to GS 22 on Shari'ah Supervisory Board appointment, functions, review and application to subsidiaries. https://aaoifi.com/issued-standards-2/?lang=en.

Governance and architecture bodies of knowledge

[19] Institute of Internal Auditors. *The IIA's Three Lines Model: An Update of the Three Lines of Defense*. Lake Mary, FL, July 2020.

[20] The Open Group. *The TOGAF Standard, 10th Edition*. 2022.

[21] DAMA International. *DAMA-DMBOK: Data Management Body of Knowledge*, 2nd edition. Technics Publications, 2017. ISBN 978-1-63462-234-9.

Source volume

[22] Khan, N. A. *AI Governance & Compliance Frameworks for the Middle East: The Enterprise Playbook*. iSystematic Inc., 2026. ISBN 978-1-0678960-1-0 (paperback); 978-1-0678960-2-7 (hardcover). MESA is specified in Chapter 4.

Appendix A. Representative assessment anchors

Four questions with their full anchor sets, one per layer. **These four are illustrative of the anchor pattern and are not the instrument.** See 7.2.

Layer 1. Does the institution maintain a current written mapping of every AI system to the jurisdictions and binding authority sources it is subject to? **L1:** no mapping. **L2:** partial mapping for some systems. **L3:** complete mapping, reviewed at least annually. **L4:** mapping reviewed at every model change and at the periodic portfolio review. **L5:** mapping used to inform proactive engagement with each authority.

Layer 2. Does the board approve a written AI risk appetite statement at least annually? **L1:** no written statement. **L2:** a statement exists but is not board-approved. **L3:** board approval annually, with limited review during the year. **L4:** board approval annually, with quarterly review against operational metrics. **L5:** the appetite is updated as the portfolio and environment evolve.

Layer 3. What share of production AI systems have current independent validation reports on file? **L1:** 0 to 25 per cent. **L2:** 26 to 60 per cent. **L3:** 61 to 90 per cent. **L4:** 91 to 100 per cent with revalidation status tracked. **L5:** 100 per cent with validation cycle-time improvement targets in force.

Layer 4. Can the institution produce a complete decision audit trail, comprising input data, model version, output and explanation artefact, for any production AI decision within its defined evidence service level? **L1:** cannot. **L2:** can for some systems. **L3:** can for all production systems within the retention window. **L4:** can for all production systems within retention, plus historic decisions on request. **L5:** can query the audit trail in real time across the portfolio.

Transition failure modes. *Policy theatre*, from 1 to 2: the policies are written and declared, and are not used in an actual decision. *Coverage gaps*, from 2 to 3: the process is institutionalized for new systems and never retrofitted. *Metrics without action*, from 3 to 4: dashboards are stood up and the readings do not change any decision. *Performative externalization*, from 4 to 5: the institution publishes claims its own internal audit findings do not support.

---

doi.org/10.5281/zenodo.22109836

Appendix B. Sharia-specific implementation profile

This appendix applies only to institutions under a Sharia Supervisory Board with binding authority. Nothing in it is a generic requirement of the framework, and the broader framework does not assume any particular institutional religious architecture.

Governance architecture. The board's authority derives from the institution's own constitution and, where the jurisdiction has adopted them, from the supervisory expectations in IFSB-10 [16] and IFSB-31 [17], with the standard-level framework in AAOIFI GS 1 (Revised 2024) and GS 19 to GS 22 [18].

Position in MESA. Binding authority source inside Layer 1 (5.1); a validation track and notification path inside Layer 3 (5.3); and, where a certification scheme has been adopted, a data-certification chain inside Layer 4.

On data certification. Where an institution operates a scheme certifying that data used in AI systems is permissible under its board's determinations, the specification requires only that the scheme be defined rather than assumed. An institution adopting one shall record: what the certification asserts; who may issue it; what evidence supports issuance; the scope of systems and data classes to which it applies; its review cadence; and whether it is treated as religious governance evidence, contractual evidence, or both. **A certification chain that is named in a control set without these six elements defined is not an evidenced control**, and shall be carried as a documented-inability record under 4.3 until it is.

Appendix C. Illustrative implementation profile

This appendix is informative and carries no normative weight. The timetable is neither a maturity requirement nor a conformance condition, and no institution is non-conformant for departing from it. It records a sequence observed in practice, offered so that an institution can compare its own plan against one worked example.

The profile runs approximately eighteen to twenty-four months for an institution starting at Level 1 across all four layers. Institutions starting higher compress it. The discipline is the phase gating, not the calendar, and a phase should not be declared complete on a date if its maturity outcome has not been evidenced.

Phase 1, Foundation. Goal: Level 1 to Level 2 across all layers. Milestones: a completed AI inventory in which every production system is named, owned and classified; a chartered governance committee on a fixed cadence; a stood-up governance office; adopted core policies covering model risk, data governance, vendor risk and incident response; first-line training for model owners and product leads. Common blockers: an inventory that takes longer than planned because no complete list existed; a committee charter drafted too thin to carry authority; an office under-resourced relative to portfolio size.

Phase 2, Operationalization. Goal: Layers 1 and 3 from Level 2 to Level 3. Milestones: an operational model risk function with a validation report on file for every system in the top two risk tiers; data classification applied across AI-relevant assets; a complete vendor risk register with the top two tiers assessed; incident runbooks for the top three severity levels; a first tabletop exercise with findings tracked to closure; a periodic portfolio review presented to the committee. Common blockers: a validation backlog larger than the office can clear in the window; business-unit resistance to data classification.

Phase 3, Scaling. Goal: Layer 3 from Level 3 to Level 4, and begin the Layer 4 build. Milestones: Layer 4 monitoring operational on the top tier, covering drift, fairness and explainability; documented cross-jurisdiction incident coordination; automated vendor monitoring where feasible; a multi-jurisdiction tabletop exercise; a board-level governance scorecard; a first independent assurance review of the model risk function. Common blockers: monitoring infrastructure investment delays; cross-jurisdiction coordination requiring legal-entity alignment beyond technical alignment.

Phase 4, Optimization. Goal: selected layers from Level 4 to Level 5, typically Layers 1 and 2. Milestones: supervisory engagement in at least one jurisdiction; published framework or industry contribution; transparency disclosure for material customer-facing systems; a maturity re-assessment producing a dated delta against the prior year. Common blockers: optimization investments difficult to justify against tactical priorities; leadership succession during the programme.

---

doi.org/10.5281/zenodo.22109836

Appendix D. Worked example, as a traceability trace

An illustrative construction, built to exhibit the cascade and enforcement-constraint properties, which means it cannot test them. It contains no measurement and reports no outcome.

Trigger. An authority in one of the institution's jurisdictions publishes a requirement that any customer-facing automated credit decision be accompanied, on request by the affected person, by an explanation of the decision in the local language, available for a defined period after the decision.

The trace. Each row completes the chain in 2.3.

Requirement	Layer 1 record	Layer 2 decision	Layer 3 control	Layer 4 enforcement mechanism	Evidence artefact
Explanation available in local language on request	Register entry naming instrument, authority, affected systems, as-of date	Continue automated decisioning and fund the substrate	Explanation-adequacy check added to the validation protocol; artefact added to the deployment gate evidence set	Explanation generated at decision time and written to an immutable per-decision record	Reproduced decision trail for a randomly sampled decision
Retention for the defined period	Conflict check against data-minimization and deletion duties in the same and adjacent jurisdictions; conflict register entry where incompatible	Accept the storage cost and the residual exposure recorded	Retention rule and supporting lineage requirement in the data governance pillar	Storage policy enforced by architecture, not by operator discipline	Retention attestation generated by the architecture
Human review where the decision is contested	Register entry against the same systems	Change the operating model for the affected segment	Gate criterion and escalation path	Workflow enforcement preventing release without recorded review	Approval record per contested decision
Vendor-supplied scoring must emit a retained explanation	Obligation-to-control trace extended to the vendor boundary	Accept vendor remediation timeline or substitute the vendor	Vendor questionnaire and contract clause; vendor file updated	Contractual and technical conformance test at integration	Vendor attestation plus integration test record

Coupling 1 then operates automatically: every model already classified at the affected tier acquires the new gate evidence requirement without the committee re-deriving the classification.

The enforcement-constraint observation. Suppose the substrate can generate the explanation but cannot retain it per decision at the required volume, and the gap will take three quarters to close. The control is runtime-dependent, so by 2.5 the institution does not record it as in force. It records documented inability under 4.3, names the compensating control and the owner, and returns the matter to Layer 2, because the appetite decision was taken on the assumption that the substrate would carry the obligation. This is the cascade running upward, and it is the case the framework exists to make visible. Classified under Section 6, the condition is **F5, enforcement failure**, and not F3, which is the misclassification that would send the institution to rebuild a control that already exists.

Appendix E. Companion specifications

Listed for orientation. **None is required to implement MESA**, except the assessment instrument, on which Section 7.2 states an explicit dependency. Identifiers are omitted where a deposit does not yet exist, rather than reserved as placeholders.

MESA Assessment Instrument. The complete fifty-question instrument with all anchors. Section 7.2 makes this document dependent on it for a conformant assessment. Deposit in preparation.

doi.org/10.5281/zenodo.22109836

Five-Gate Deployment Model. The deployment decision structure referenced in 5.3: five checkpoints between an approved idea and production, each carrying entry criteria, approval authority, required evidence, exit criteria and rejection path. Specified in Chapter 10 of [22]. Specification: https://doi.org/10.5281/zenodo.22170122.

PEVG: Planner, Executor, Verifier, Generator. A reference architecture in which four roles are held by separate components, the verifier holds binding judgement on truth, and the generator may assert only verifier-surviving claims. Its relevance is specific: an institution that uses AI systems to help govern its AI systems has created a self-assessment problem, and PEVG is the separation that prevents a component from both producing and validating the same claim. An institution applying MESA with AI assistance should apply PEVG to that assistance. Introduced in *Prompt Systems and Agent Orchestration*, Book 2 of the Full-Stack AI Engineering Series. Specification: https://doi.org/10.5281/zenodo.22170132.

PARA: Perception, Action, Reasoning, Adaptation. A four-faculty operating model for agents acting inside a governed environment, with adaptation bounded by the same guardrails as action. Its Layer 4 relevance is that an agent taking consequential action shall record the reasoning that justifies it, which is the same evidence requirement 5.4(c) places on a model producing a decision. The acronym reads P-A-R-A; the loop runs perception, then reasoning, then action, then adaptation. No trademark is claimed on the name. Introduced in *DevOps for AI-Native Platforms*, Book 3 of the Full-Stack AI Engineering Series. Specification: https://doi.org/10.5281/zenodo.22170139.

A Pattern Language for Production LLM Platforms. A specification of a three-layer reference architecture and a pattern catalogue for large language model platforms in regulated environments, unified by one invariant: a boundary is a clause the optimiser may not cross, and everything else is optimization. Layer 1 of MESA is the institutional statement of that invariant. **Deposited. Concept DOI https://doi.org/10.5281/zenodo.22109864**, which resolves to the latest version. Version 1.1 of that specification names the invariant **the Boundary Invariant** and names **the BOE Declaration**, and neither name carries a trademark.

The Defensible AI Framework Registry. The canonical source for the names, definitions, versions and relationships of the governance-family frameworks, of which MESA is the diagnostic frame. It records this specification as the parent of seven of its nine entries, and it is where a reader goes to find which framework instantiates which altitude. Specification: https://doi.org/10.5281/zenodo.22170112.

Document history

Version 1.1, 30 August 2026. Two scope and naming clarifications. **No normative change to the four altitudes, the five operating mechanisms, the conformance language at 7.5, the clause-level mappings in Section 3, the falsification conditions at 8.3 or the research agenda at 8.4.**

- The acronym expansion is revised from *Middle East Strategic Alignment* to **Maturity, Evidence, Substrate, Alignment**. A new section, On the name, placed immediately after the abstract, derives each term from language already present in version 1.0 and states explicitly that the four terms are not the four altitudes. The prior expansion described the framework's origin rather than its scope, and the framework's scope statement in version 1.0 was already jurisdiction-neutral. The regional origin is a matter of record and is not disclaimed.
- **7.6 supersedes the Governance Maturity Model** published in the Enterprise Playbook, with an informative mapping table from the prior five-level model and a statement of why the fourth profile position cannot be inferred from a prior result. The two instruments answer the same question and shall not be operated in parallel.
- **Appendix E corrected.** A Pattern Language for Production LLM Platforms was recorded as a working draft with no identifier. It was deposited on 26 August 2026 and its concept DOI is now given. The Defensible AI Framework Registry is added, with its identifier omitted rather than reserved, following the convention this appendix already states.

Version	Date	Class	Change
0.9	26 August 2026	Internal draft	First complete normative draft, derived from Chapter 4 of [22] and restructured as a standalone document with clause-level prior-art mapping

doi.org/10.5281/zenodo.22109836

Version	Date	Class	Change
1.0	26 August 2026	First public release	Independent editorial review incorporated before first publication. Governance altitude formally defined; contribution restated as one architecture with five supporting mechanisms; four-layer relationship formalized in 2.4; capping rule qualified to runtime-dependent controls only (2.5); governance dependency separated from remediation priority (2.6, 7.4); maturity scoring extended to mean, minimum and critical-control floor (7.3); assessment instrument moved to a companion specification with an explicit dependency (7.2); ”material change” defined (1.2); requirement, control, enforcement and evidence distinguished (1.2, 2.3); failure taxonomy added (Section 6); regulatory snapshot discipline added (Section 9); research agenda added (8.4); evidence service level made institution-defined with twenty-four hours as reference value (5.3); implementation profile moved to an informative appendix; companion specifications moved to an appendix with placeholder identifiers removed; prior-art claims restated as instantiation rather than correction

Future releases will classify each change as **normative**, **editorial** or **reference update**.

About the author

Nabeel Khan is an enterprise AI architect and governance advisor, and Founder & Solutions Architect at iSystematic Inc. He has spent twenty-five years architecting enterprise data and machine-learning systems in government, healthcare, financial services and telecommunications across three continents, grounded in TOGAF, DMBOK, ISO 27001 and SOC 2.

He works on governed production AI; systems whose authority is bounded by the architecture, whose decisions carry the evidence needed to defend them, and whose behaviour the institution can explain afterwards. The frameworks specified here, and the regulatory knowledge behind them, are published as machine-accessible AI expertise and are callable over MCP without a key at mcp.nabeelkhan.com/api/mcp, so a reader may query this specification's contents directly and receive answers carrying their source.

ORCID 0009-0005-5364-914X · nabeelkhan.com · Canada

Licence

This work is licensed under a Creative Commons Attribution 4.0 International licence (CC BY 4.0). It may be copied, redistributed, adapted and built upon for any purpose, including commercially, provided appropriate credit is given, a link to the licence is provided, and changes are indicated. Full licence text: https://creativecommons.org/licenses/by/4.0/.

The licence covers the text of this specification. It grants no rights in the trademarks identified in the trademark notice on the title page.

How to attribute this work

This work is licensed CC BY 4.0. Section 3(a)(1)(A) of that licence requires attribution in the manner the licensor requests, and Section 3(a)(1)(C) requires a link to the material where practicable. This section is that request. Please use one of the following.

Short credit, for slides, diagrams and internal documents:

```
The MESA Framework™ by Nabeel Khan ·
  https://nabeelkhan.com/frameworks/mesa · CC BY 4.0
```

Inline credit, for web pages, articles and product documentation:

doi.org/10.5281/zenodo.22109836

```
Based on <a href="https://nabeelkhan.com/frameworks/mesa">The MESA
  Framework™</a> by Nabeel Khan,
licensed under <a href="https://creativecommons.org/licenses/by/4.0/">CC
  BY 4.0</a>.
```

Academic citation:

```
Khan, N. A. (2026). The MESA Framework: A Four-Altitude Diagnostic Model
  for Institutional AI Governance.
(Version 1.1). Zenodo. https://doi.org/10.5281/zenodo.22109836
```

The DOI given is the concept DOI and always resolves to the latest version. Cite it unless you need to pin one specific version.

If you have adapted the work, say that changes were made, and do not imply that this author or iSystematic Inc. endorses your version.

Trademarks. MESA Framework™ is a trademark of the author and iSystematic Inc. The CC BY licence covers the text and figures and grants no rights in the mark. Do not use the mark as, or as part of, the name of your product or service.

doi.org/10.5281/zenodo.22109836